

ATT&CK Based Practice Guide Evaluation

Final Report

December 6, 2019

Institution: The University of Texas at Dallas - Team Lost Girls

Team Members:

Anmol Agarwal	Anmol.Agarwal@utdallas.edu
Rhiannon Jones	Rhiannon.Jones@utdallas.edu
Evelyn Wong	Evelyn.Wong@utdallas.edu

Table of Contents

Table of Contents	2
Project Summary	3
Description	3
Team Responsibilities	3
Total Budget	4
Motivation	4
Organization	4
Plans	4
Deliverables	4
Schedule	4
Budget	5
Broader Impact	5
Team Approach and Justification	5
Results	6
Tabletop Exercise	6
Exercise 1	6
Privilege Escalation	6
What is your response?	6
Discussion questions	6
Processes tested: Privilege Escalation	6
Threat actor: External Threat	6
Asset impacted: Internal Network	6
Applicable MITRE ATT&CK Tactics and Techniques:	6
Exercise 2	8
Flooding Attack	8
What is your response?	8
Discussion questions	8
Processes tested: Account Administration	8
Threat actor: External Threat	8
Asset impacted: Internal Network	8
Applicable MITRE ATT&CK Tactics and Techniques:	8
Exercise 3	10
Account Manipulation	10

What is your response?	10
Discussion questions	10
Processes tested: AlertEnterprise Approval Process	10
Threat actor: External Threat	10
Asset impacted: Internal Network	10
Applicable MITRE ATT&CK Tactics and Techniques:	10
After Action Report	11
Future Work	11
Literature Review	11
1 MITRE ATT&CK™: Design and Philosophy	11
2 Finding Cyber Threats with ATT&CK™: Based Analytics	12
3 Towards a definition of cyberspace tactics, techniques and procedures	12
4 Caldera	13
Biographical Sketches of Investigators	13
Anmol Agarwal	13
Rhiannon Jones	14
Evelyn Wong	14
References	14

Project Summary

Description

NCCoE Practice Guides target cybersecurity challenges. These guides are helpful and provide easy ways to adopt standards-based approaches to cybersecurity. The goal of this project is to identify any security gaps in the Access Rights Management Practice Guide's architecture by analyzing the test cases in the NCCoE Practice Guide. Specifically, this project aims to find the techniques and tactics the Practice Guide protects against by evaluating the scenarios in the guide against the attacks in the MITRE ATT&CK Enterprise Matrix. The team will document their findings while analyzing the different techniques.

Team Responsibilities

- Review the architecture in Volume B, Access Rights Management for the Financial Services Sector [4]
- Specify appropriate techniques and tactics that is applicable to attack the framework.

- Perform a Tabletop exercise to attack the framework described in Volume B and document results
 - Attacks will change directories and account attributes
- Review Tabletop exercise results in After Action Report

Total Budget

The team spent ten hours per week on the project.

Motivation

The architectures described in the NCCoE Practice Guides are theoretical and have never been evaluated or tested. By performing tabletop exercises to attempt to attack the framework described in Volume B of the Access Rights Management Practice Guide [4], this project will help evaluate the architecture for the first time and help to improve the architecture by exposing any flaws in its design.

Organization

Plans

The group met weekly to ensure progress on the project. The team used effective time management and communication to ensure that the project continues to progress on schedule.

Deliverables

- Proposal & Literature Review
- Progress Report & Presentation
- Tabletop Exercise Report
- After Action Report
- Final Report & Presentation

Schedule

October 4: Proposal Due
October 11: Read Volume B of the Access Rights Management Practice Guide
October 18: Review ATT&CK Matrix
October 25: Plan Tabletop Exercise
November 1: Midterm Report Due
November 8: Perform Tabletop Exercise
November 15: Finish Tabletop Exercise

November 15: Report Draft of Tabletop Exercise
November 22: Draft After Action Report
November 27: Finish Tabletop Exercise Report and After Action Report
December 4: Review Final Report
December 6: Final Deliverables Due

Budget

There are no monetary costs associated with this project. The team met approximately ten hours/week and had weekly status update meetings.

Broader Impact

By analyzing the tactics and techniques that the NCCoE Access Rights Management Practice Guide protects against, the security of the architecture in the Volume B of the Access Rights Management Practice Guide can be improved and strengthened.

Team Approach and Justification

The team performed a tabletop exercise to uncover any flaws in the architecture. First, the team worked to brainstorm attack scenarios, and then, the team performed a tabletop exercise that detailed MITRE ATT&CK techniques and tactics that would be used in the attack scenario. The tabletop exercise also included data sources that would indicate whether an attack has taken place. The data sources were sources that could be found on Windows systems, such as Windows error codes or event logs.

After performing the tabletop exercise, the team evaluated the tabletop exercise results with the After Action Report. The After Action Report evaluated whether the attack scenarios would be successful or not by analyzing how the system would respond if the attack scenario had taken place.

Results

Exercise 1

Privilege Escalation

SCENARIO: An attacker finds and exploits a vulnerability in one of the tools in your system. From there, the attacker moves laterally through the system until they are able to escalate the privileges of the account they've exploited or create a new high privilege account that can access the system.

What is your response?

Discussion questions

- How would the system respond to this attack?
 - Would this attack be detected?
- How could this attack be prevented?
- How would your company respond to this attack?
 - How would you mitigate the damage?

Processes tested: Privilege Escalation

Threat actor: External Threat

Asset impacted: Internal Network

Applicable MITRE ATT&CK Tactics and Techniques:

Tactics: [TA0004](#) - Privilege Escalation, [TA0008](#) - Lateral Movement, [TA0001](#) - Initial Access, [TA0005](#) - Defense Evasion, [TA0006](#) - Credential Access

Techniques: [T1190](#) - Exploit Public-Facing Application, [T1098](#) - Account Manipulation, [T1068](#) - Exploitation for Privilege Escalation, [T1075](#) - Pass the Hash, [T1211](#) - Exploitation for Defense Evasion

Exercise 1 - Privilege Escalation

Tactic ID	Tactic	Technique ID	Technique Name	Data Source 1	Data Source 2	Data Source 3	Data Source 4
TA0001	Initial Access	T1190	Exploit public facing Application	Application Logs	Packet Capture	Web Logs, Web Application Firewall Logs	
TA0004	Privilege Escalation	T1068	Exploitation for Privilege Escalation	1000, 1001 Windows Error Reporting	4688 Process Execution	Application Logs	
TA0005	Defense Evasion	T1211	Exploitation for Defense Evasion	4688 Process Execution	4663 File Monitoring	1000, 1001 Windows Error Reporting	
TA0006	Credential Access	T1098	Account Manipulation	4624 Authentication Logs	Windows Event Logs	Packet Capture	API monitoring
TA0008	Lateral Movement	T1075	Pass the Hash	4624 Authentication Logs			

After Action Report

In the event of any account changes, a log event is generated when a new account is created or when the privileges for an account are escalated. Therefore, the system would be able to detect this attack and generate an alert that the privilege escalation attack is occurring.

In order to prevent the attack, security patches should be installed as soon as they are available. This would reduce the probability that an attacker could find a vulnerability to exploit.

As a company facing this issue, the best response would be to revert the changes that were made. In addition, the account should be removed to prevent any further damage.

Exercise 2

Flooding Attack

SCENARIO: An attacker gains access to your account database, but the attacker knows that you're using the Access Rights Management Practice Guide as the basis of your system. Instead of adding a single high-privileged account, the attacker floods your account database with new high-privileged accounts. While your security analysts are trying to revert the changes, the attacker uses the high-privileged accounts to access your system.

What is your response?

Discussion questions

- How would the system respond to this attack?
 - Would this attack be detected?
- How could this attack be prevented?
- How would your company respond to this attack?
 - How would you mitigate the damage?

Processes tested: Account Administration

Threat actor: External Threat

Asset impacted: Internal Network

Applicable MITRE ATT&CK Tactics and Techniques:

Tactics: [TA0040](#) - Impact, [TA0005](#) - Defense Evasion, [TA0004](#) - Privilege Escalation

Techniques: - T1499 - Endpoint Denial of Service, [T1068](#) - Exploitation for Privilege Escalation, [T1496](#) - Resource Hijacking, [T1492](#) - Stored Data Manipulation, [T1485](#) - Data Destruction, [T1222](#) - File and Directory Permissions Modification

Exercise 2 - Flooding Attack

Tactic ID	Tactic	Technique ID	Technique Name	Data Source 1	Data Source 2	Data Source 3	Data Source 4
TA0004	Privilege Escalation	T1068	Exploitation for Privilege Escalation	1000, 1001 Windows Error Reporting	4688 Process Execution	Application Logs	
TA005	Defense Evasion	T1222	File and Directory Permissions Modification	4663 File Monitoring	Process Monitoring	4688 Process command-line parameters	Windows event Logs
TA0040	Impact	TA1499	Endpoint Denial of Service	SSL/TLS Inspection	Web Logs	Web Application Firewall Logs	Network Device Logs
TA0040	Impact	T1496	Resource Hijacking	Azure activity Logs	Process use of network	Process Monitoring	Network Protocol Analysis
TA0040	Impact	T1492	Stored Data Manipulation	Application Logs	File Monitoring		
TA0040	Impact	T1485	Data Destruction	4663 File Monitoring	4688 Process Command Line Parameters	Process Monitoring	

After Action Report

In the event of any account changes, a log event is generated when the privileges for an account are escalated. The system would be able to detect the privilege escalation attacks and will generate an alert that privilege escalation attacks are occurring. In this scenario, there will be a large number of privilege escalation attacks so that a large number of alerts are generated by the system. The system administrators will be preoccupied with reverting all of the changes from the high privileged accounts, so the administrators might not notice that one account is accessing the system resources.

The system will generate an alert that the attacker is accessing system resources, so the system would be able to detect this attack. This attack could still be successful because system administrators will have to address all alerts that were generated, and there might be a delay before the administrators detect system resource access.

In order to prevent this attack, security patches should be installed as soon as they are available. This would reduce the probability that an attacker could find a vulnerability to exploit that would let the attacker escalate privileges.

The best response from a company facing this issue would be to revert the changes that were made as soon as possible, and the accounts should be removed to prevent further damage.

Exercise 3

Account Manipulation

SCENARIO: An attacker gains access to your AlertEnterprise installation. The attacker changes the access approval owner to an account they control. With their newfound approval authority, the attacker creates new accounts and escalates the privileges of their newly created accounts.

What is your response?

Discussion questions

- How would the system respond to this attack?
 - Would this attack be detected?
- How could this attack be prevented?
- How would your company respond to this attack?
 - How would you mitigate the damage?

Processes tested: AlertEnterprise Approval Process

Threat actor: External Threat

Asset impacted: Internal Network

Applicable MITRE ATT&CK Tactics and Techniques:

Tactics: - TA0002 - Execution, TA0003- Persistence, [TA0004](#) - Privilege Escalation, [TA0005](#) - Defense Evasion, [TA0040](#) - Impact

Techniques: [T1204](#) - User Execution, [T1098](#) - Account Manipulation, [T1068](#) - Exploitation for Privilege Escalation, [T1222](#) - File and Directory Permissions Modification

Exercise 3 - Account Manipulation

Tactic ID	Tactic	Technique ID	Technique Name	Data Source 1	Data Source 2	Data Source 3	Data Source 4
TA0002	Execution	T1204	User Execution	4688 Process Command Line	4688 Process Execution	Anti - virus	
TA0003	Persistence	T1098	Account Manipulation	4624 Authentication Logs	Windows Event Logs	Packet Capture	API monitoring
TA0004	Privilege Escalation	T1068	Exploitation for Privilege Escalation	1000, 1001 Windows Error Reporting	4688 Process Execution	Application Logs	
TA0040	Impact	T1222	File and Directory Permissions Modification	4663 File Monitoring	Process Monitoring	4688 Process command-line parameters	Windows event Logs

After Action Report

The system will generate an alert when the AlertEnterprise owner changes, and, even though the attack has made herself the owner and can approve changes, the system will generate log events when privileges are escalated. As such, the system will detect the attack as soon as the attacker changes the AlertEnterprise owner and will record all of the attacker's changes to account privileges.

In order to prevent this attack, the company should regularly monitor who the owner of the AlertEnterprise approval process is and generate alerts when logs are generated because the AlertEnterprise owner changes. In addition, the company should also install security patches as soon as they are available to reduce the damage that can be inflicted from this attack.

The best response from the company would be to revert the changes that were made, and the account should be removed to prevent further damage. In addition, the system administrator should change the configuration in the AlertEnterprise installation to prevent the attacker from using the AlertEnterprise installation.

Future Work

In the future, other teams will perform the tabletop exercise again in an attempt to find more attacks against the architecture. The idea of the tabletop exercise is that a tabletop exercise will be done continuously in order to continuously improve the architecture.

Literature Review

1 MITRE ATT&CK™: Design and Philosophy

This paper describes the MITRE ATT&CK framework. ATT&CK is a knowledge base for the behavior of malicious cybersecurity actors. It has tactics and techniques that the adversaries use to exploit certain software. Tactics are the short term goals that the attacker uses and the techniques are the actions the malicious user does in an attempt to exploit the software. ATT&CK can be visualized in a matrix with tactics representing the columns of the matrix and the techniques representing the rows of the matrix.

ATT&CK covers the following technological domains: macOS, Linux, Windows, Android, and iOS. ATT&CK describes cybersecurity exploits by depicting them from the malicious user's point of view, is based on actual examples that occurred, and helps to determine possible defensive strategies from the offensive strategies.

ATT&CK is a useful framework for emulating adversarial behavior and can help blue teams develop defensive strategies by observing the attacker behavior from ATT&CK.

2 Finding Cyber Threats with ATT&CK™: Based Analytics

This paper describes a methodology for using a behavior-based threat model (MITRE ATT&CK) to develop detection capabilities that detect adversaries through the use of adversary emulation. The methodology includes seven steps: Identify Behaviors, Acquire Data, Develop Analytics, Develop an Adversary Emulation Scenario, Emulate Threat, Investigate Attack, and Evaluate Performance.

The focus of the Identify Behaviors step is to identify the adversary behaviors to detect and to prioritize them. The Acquire Data step aims to find what data is necessary to identify the targeted adversary behaviors and create sensors to collect any data that does not have a current collection capability. Develop Analytics creates the analytics used to detect the behaviors identified in the

first step. Next is to Develop an Adversary Emulation Scenario which develops a scenario that emulates adversary behavior including the identified behaviors from step one. The Emulate Threat step and Investigate Attack threats are Red Team/Blue Team activities where the Red Team attempts to carry out the objectives defined in the emulation scenario and the Blue Team attempts to detect the Red Team's activities using the analytics developed in the third step. The final step is to Evaluate Performance where the entire engagement is reviewed and the extent to which adversary behaviors were detected with the developed analytics and sensors.

3 Towards a definition of cyberspace tactics, techniques and procedures

This paper define TTPs which stands for Tactics, Techniques and Procedures. It describes an approach to developing models of offensive cyberspace operations (OCO). Developing actionable behavioral models of OCO for an autonomous system allow defensive systems to detect attacks and predict future actions. The model described discussed how it applies to real-world cyberspace operations examples. Given an attack graph, an attacker emulator could work backwards. Their approach captures optional elements where they're able to show a representation of all known permutations of an attack and still add new variations as they are observed. This approach is compatible with ATT&CK. In 2015, MITRE released its Adversarial Tactics, Techniques (ATT&CK) model, that takes about post-compromise behaviors [2]. In which, ATT&CK describes ten categories of tactics.

The model of Advanced Persistent Threat (APT) 28 technique is used with the approach describes how it can be applied to real-world cyberspace operations. It also explains their approach and how it could be used by Machine Learning (ML) algorithms to detect and represent an ongoing attack. Research this approach on TTPs help provide predictive analytics based on large security datasets.

4 Caldera

Caldera is an automated red team tool. It uses the ATT&CK model to replicate adversary behaviors, thereby enabling automated assessments of a network's security. Caldera uses a decision engine to choose actions in combination with an adversary representation language, the ATT&CK matrix, and an agent to conduct the operation to test a network's defenses. This tool allows for the detection of, and subsequent response to, adversary behavior [5].

Biographical Sketches of Investigators

Anmol Agarwal

Anmol Agarwal is currently pursuing her Bachelor's degree in Software Engineering with a specialization in information assurance and her Master's degree in Computer Science with a specialization in information assurance concurrently. She is also an NSF CyberCorps Scholarship for Service recipient. She has experience in software development, project management, virtual machines, and information security. Anmol has experience with solving CTF (Capture the Flag) challenges, such as challenges in web security and forensics. She has completed coursework in computer networks, digital forensics, information security, artificial intelligence, operating systems, and data and applications security. She is currently taking network security and advanced operating systems. In her free time, Anmol is an active member of Women in CyberSecurity and the Computer Security Group.

Rhiannon Jones

Rhiannon Jones holds a Bachelor's degree in Computer Science and is pursuing a Master's degree in Computer Science with a specialization in information assurance. She has completed an internship with Experian in their Global Security Office, working as a part of the Governance and Controls team. She has experience in virtual machines, vulnerability assessments, software development, and information security. She has related coursework in software engineering, computer networks, information security, operating systems, machine learning, and language-based security. She is currently taking classes in advanced operating systems, machine learning, and network security.

Evelyn Wong

Evelyn Wong is a senior Computer Science major, with a specialization in information assurance. She is currently a fast track student and working on a master's degree in computer science while finishing undergraduate studies. She is also a recipient of the CyberCorps: Scholarship for Service. She has experience practicing and studying attacking techniques and vulnerability in computer and network systems. She has completed related coursework in software engineering, operating systems, computer architecture, computer network security. She is currently taking computer networks, database design, and automata theory.

References

- [1] B. Strom, A. Applebaum, D. Miller, K. Nickels, A. Pennington and C. Thomas. (2018). "MITRE ATT&CK™: Design and Philosophy," [online] McLean, VA: MITRE Corporation.
Available at: <https://www.mitre.org/sites/default/files/publications/pr-18-0944-11-mitre-attack-design-and-philosophy.pdf> [Accessed 27 Sep. 2019].
- [2] B. E. Strom, J. A. Battaglia, M. S. Kemmerer, W. Kupersanin, D. P. Miller, C. Wampler, S. M. Whitley and R. D. Wolf, "Finding Cyber Threats with ATT&CK-Based Analytics," 2017. Available at: <https://www.mitre.org/sites/default/files/publications/16-3713-finding-cyber-threats%20with%20att&ck-based-analytics.pdf> [Accessed 27 Sep. 2019].
- [3] F. Maymí, R. Bixler, R. Jones and S. Lathrop, "Towards a definition of cyberspace tactics, techniques and procedures," 2017 IEEE International Conference on Big Data (Big Data), Boston, MA, 2017, pp. 4674-4679. doi: 10.1109/BigData.2017.8258514. Available at: <https://ieeexplore.ieee.org/abstract/document/8258514> [Accessed 27 Sep. 2019].
- [4] J. Banoczi, S. Edwards, N. Irrechukwu, J. Klosterman, H. Perper, S. Prince, S. Symington, and D. Wynne, "Access Rights Management for the Financial Services Sector," National Institute of Standards and Technology Special Publication, Gaithersburg, MD, 2017.
- [5] The MITRE Corporation. (2019). CALDERA. [online] Available at: <https://www.mitre.org/research/technology-transfer/open-source-software/caldera> [Accessed 27 Sep. 2019].